— numéro 033 —

L'Oracle du Matin

PRIX · UN CAFÉ · ÉDITION DU MATIN · 033

✦ CE QUE DEMAIN NOUS RÉSERVE, LU CE MATIN ✦

ÉDITION DU MATIN
Dimanche 1 novembre 2026
QUATRE COLONNES · DEUX PAGES

LE CHIFFRE DU JOUR

11 h

d'exposition d'une extension piégée, le 29 octobre.

LE MOT DU JOUR

Atteignabilité

n. f. — définition en page 2.

DANS CE NUMÉRO

2 Irritant — Votre éditeur met à jour ses extensions sans vous demander
2 Idée — Replica Hub clé en main : héberger les prototypes IA d'une équipe
2 IA — Agent Merge : Copilot débloque une pull request à votre place
2 Tech — Dependabot dit si la faille de votre dépendance vous concerne
1 Tech — Vercel Flags démarre 7 fois plus vite

☞ À LA UNE · IA

FIGMA RACONTE COMMENT IL A ENTRAÎNÉ SON PROPRE MODÈLE D'ÉDITION

L'agent qui modifie vos écrans s'appuie de plus en plus sur un modèle maison, post-entraîné sur un modèle ouvert.

EXCLUSIF

Le 29 octobre, Figma a publié le récit de l'entraînement du modèle qui fait fonctionner son agent d'édition. Le modèle évalué, qui n'est pas publié, est post-entraîné à partir de Qwen 3.8 27B. Un premier pipeline utilisait Llama 3.3 70B, entraîné sur plus de 250 000 exemples.

Chaque exemple associe un design de départ, une demande d'édition synthétique et une modification réussie. Les designs sont représentés dans le format de fichier natif de Figma ; de plus grands modèles « enseignants » produisent les éditions, vérifiées par des validateurs déterministes et des juges visuels. Figma ajoute de l'apprentissage par renforcement, car l'entraînement supervisé seul pousse à imiter les designs vus.

Sur le test interne « Figma design edits v3 », le modèle atteint 77,8 %, contre 76,9 % pour Sol 6.1. Entre la bêta et la disponibilité générale, l'agent est environ 20 % plus rapide, les annulations baissent de 60 % et les notes des utilisateurs montent de 33 %. Figma attribue ces gains à l'ensemble modèles, outils et harnais, pas au seul modèle.

Retenue utile : ces scores sont internes et un seul autre modèle figure sur le graphique. Les modèles tiers servent toujours pour les images et les vecteurs.

TECH ÉCLAIR

VERCEL FLAGS DÉMARRE 7 FOIS PLUS VITE

Annoncé le 29 octobre : à froid, l'initialisation du SDK passe de plus de 70 ms à 10 ms (p75, tests internes de Vercel), et la lecture d'un flag reste sous 1 ms (p99). Les fonctions ne sont plus prolongées pour le reporting d'usage. Il faut *@flags-sdk/vercel* 1.5.3 ou plus, puis redéployer.

LE LAB VOUS RÉPOND

L'énigme

Je préviens sans fermer, je trie sans décider ; sur mon verdict, certaines failles passent en tête de liste et d'autres restent en bas. Qui suis-je ?

Réponse : le verdict d'atteignabilité d'une alerte de sécurité

L'IRRITANT DU JOUR

VOTRE ÉDITEUR MET À JOUR SES EXTENSIONS SANS VOUS DEMANDER

Les mises à jour automatiques sont pratiques, jusqu'au jour où l'une est piégée.

Le 29 octobre, Cursor a signalé que les versions 2.1.312 et 2.1.313 de l'extension « Anthropic.claude-code », sur Windows et macOS, avaient été diffusées depuis sa place de marché d'extensions sans avoir été publiées par Anthropic. Elles pouvaient collecter le nom d'hôte, l'e-mail Git et l'adresse IP publique, et tenter d'ouvrir un accès SSH à distance, entre environ 2 h 27 et 13 h 35, heure du Pacifique. Désinstaller ne suffit pas : il faut chercher une clé SSH et renouveler ses identifiants.

VS Code a introduit en juin un délai de deux heures avant la mise à jour automatique d'une extension, sauf pour les éditeurs de confiance, ce qu'InfoQ juge court. On ignore s'il s'applique à Cursor.

PISTE DE BUSINESS

Un service de quarantaine pour extensions d'éditeur : une liste approuvée par équipe, et chaque nouvelle version bloquée sept jours. Cible : agences et petites équipes sans service informatique. Concurrence : les listes d'autorisation et places de marché internes que l'article d'InfoQ cite, mais qui demandent du temps. L'angle : un réglage, un rapport par semaine.

L'IDÉE DE BUSINESS

REPLICA HUB CLÉ EN MAIN : HÉBERGER LES PROTOTYPES IA D'UNE ÉQUIPE

GitHub ouvre un outil de prototypage dont le partage d'équipe exige son propre serveur.

Le 28 octobre, GitHub a présenté Replica, un outil open source (MIT) créé par GitHub Design et Microsoft CoreAI Design. On décrit un écran en langage naturel dans l'application GitHub Copilot, et l'outil produit un prototype interactif qui reprend les composants du design system de l'équipe.

En local, Replica marche sans serveur. Pour partager des prototypes et recueillir des commentaires, il faut un Replica Hub que l'organisation exploite elle-même : serveur Linux, domaine dédié avec DNS générique et HTTPS, autorisations GitHub.

L'idée : proposer ce Hub en abonnement géré. Qui paie : des équipes produit et design de quelques personnes, sans administrateur système. Lancement : déploiement automatisé, domaine fourni, facture mensuelle fixe, testés avec trois équipes. Concurrence : l'auto-hébergement, et une offre possible de GitHub. Une recherche rapide n'a pas montré d'offre hébergée de ce type.

Coût de lancement	●○○
Difficulté	●●○
Potentiel	●●○

L'IA EN PRATIQUE

AGENT MERGE : COPILOT DÉBLOQUE UNE PULL REQUEST À VOTRE PLACE

Un bouton, « Watch and fix », corrige ce qui empêche une pull request d'être fusionnée.

Annoncé le 28 octobre, Agent Merge traite les workflows GitHub Actions en échec et les conflits de fusion. Il existait dans l'application Copilot et Visual Studio Code ; il arrive dans les pull requests sur GitHub.

Mode d'emploi : dans la zone de fusion, cliquer sur « Watch and fix » et choisir les blocages à surveiller. Quand l'un apparaît, Copilot lance un travail dans un environnement cloud pour le corriger. Activable par défaut dans les réglages de Copilot.

Associé à la fusion automatique, la pull request reste prête et GitHub la fusionne dès que les exigences sont remplies : relisez ce que l'agent a poussé, et n'activez cela que là où les tests sont fiables. Plan Copilot payant requis ; la page ne donne ni tarif ni statut précis.

LA TECH

DEPENDABOT DIT SI LA FAILLE DE VOTRE DÉPENDANCE VOUS CONCERNE

En préversion publique depuis le 28 octobre, l'analyse d'atteignabilité cherche des chemins d'appel entre votre code et les fonctions vulnérables de vos dépendances, et note chaque alerte : *Reachable*, *Potentially reachable* (à traiter comme atteignable), *Unreachable* (priorité plus basse) ou *Reachability unavailable*. Aucune alerte n'est fermée automatiquement.

Limites : JavaScript et TypeScript avec un lockfile npm, Yarn ou pnpm ; GitHub Enterprise Cloud ; runners hébergés par GitHub ; désactivée par défaut (Settings > Advanced Security). Gratuit pendant la préversion.

L'ŒIL DU BUSINESS

Les petites équipes hors Enterprise n'ont pas ce tri : un marché pour d'autres langages.

LE MOT

Atteignabilité, *n. f.* : Pour une faille dans une dépendance : le fait que votre code appelle réellement la fonction vulnérable. Une alerte « inatteignable » existe toujours, mais passe après celles qui vous touchent vraiment.

LA QUESTION

Combien d'extensions d'éditeur, de plugins ou de GitHub Actions se mettent à jour toutes seules chez vous ? Lesquelles installeriez-vous sans les relire, et qui, dans votre équipe, saurait dire quelle version tourne aujourd'hui ?

CARNET DU LECTEUR — UN IRRITANT CROISÉ AUJOURD'HUI, UNE IDÉE :

L'Oracle du Matin — journal du matin rédigé et composé par Claude pour 1977 Éditions, sur une idée de Michael Misran.
Sources : figma.com · cursor.com · infoq.com · github.blog · github.com · vercel.com